

VisitFlow

VisitFlow 관리자 가이드

버전	v2.8.2
작성일	2026-09-17
문서	VisitFlow 관리자 가이드

VisitFlow 관리자 가이드

VisitFlow v2.7.3 기준. 화면을 쓰는 사람을 위한 안내(방문 신청, 로비 체크인, 승인)는 [사용자 가이드](#)에, API·MCP 명세는 [API 및 MCP](#)에, 내부 구조는 [아키텍처](#)에 있다. 이 문서는 그것들을 반복하지 않고 가리킨다.

1. 구성 요소

구성 요소	무엇	주요받는 것
visitflow 컨테이너	Go API + 빌드된 React UI + 알림 발송기·유지보수 작업이 한 프로세스에 들어 있다. 이미지 하나(<code>visitflow:vX.Y.Z</code> , <code>visitflow:latest</code> 별칭).	:8080 으로 HTTP를 받고, PostgreSQL에만 접속한다. 런타임에 CDN·레지스트리·인터넷이 필요 없다.
PostgreSQL 14+	유일한 상태 저장소. 설정·방문·방문자(암호화)·알림 큐·감사 로그·세션·로그인 잠금 정보가 모두 여기 있다.	컨테이너가 POSTGRES_DSN 으로 접속. 스키마는 기동 시 자동 마이그레이션.
리버스 프록시 (권장)	HTTPS 종료. 카메라 스캔과 Secure Cookie는 HTTPS에서만 동작한다.	X-Forwarded-Proto · X-Forwarded-Host 를 전달하고, 접속 IP를 쓰려면 X-Forwarded-For 와 함께 신뢰할 Reverse Proxy 등록(7절).
Keycloak (선택)	OIDC SSO.	Discovery + Authorization Code/PKCE. 콜백 <code>/api/v1/auth/oidc/callback</code> .
SMTP 서버 (선택)	승인 대기·메일 알림·비밀번호 재설정 메일.	관리자 UI에서 설정, 컨테이너가 발신.
문자·카카오키 Gateway (선택)	방문자·담당자 문자.	관리자 UI에 등록한 Base URL/Path/Method/Header/Parameter로 호출. MMS QR 이미지는 Gateway가 <code>/img/visitor/{seq}.jpg</code> 를 가져간다.
Prometheus (선택)	운영 지표 수집.	토큰으로 보호되는 <code>GET /metrics</code> .

애플리케이션 컨테이너는 읽기 전용 루트 파일시스템(`read_only: true`), `/tmp tmpfs 128MB`, 모든 `capability drop`, `no-new-privileges` 로 돈다. 영속 볼륨은 없다 — 상태는 전부 PostgreSQL에 있다.

2. 설치

PostgreSQL 14+ 데이터베이스와 계정을 먼저 준비한다. 아래는 GitHub Release 자산 `visitflow-v2.7.3.tar.gz` 를 펌웨어로 반입한 뒤의 절차이며, 저장소의 `compose.yaml` 을 같은 디렉터리에 둔다.

```
# 1. 이미지 반입 — 아카이브에 visitflow:v2.7.3 과 visitflow:latest 별칭이 들어 있다
gzip -t visitflow-v2.7.3.tar.gz
docker load < visitflow-v2.7.3.tar.gz

# 2. 네 개의 환경 변수 — 이 값 외의 운영 설정은 모두 관리자 UI에서 바꾼다
export POSTGRES_DSN='postgres://visitflow:CHANGE_ME@postgres.intra:5432/visitflow?sslmode=require'
export BOOTSTRAP_ADMIN='admin'
export BOOTSTRAP_ADMIN_PASSWORD='change-this-strong-password' # 12자 이상
export ENCRYPTION_KEY="$(openssl rand -base64 32)" # 한 번 만들고 반드시 별도 보관

# 3. 기동과 준비 상태 확인
docker compose up -d
curl -s http://127.0.0.1:8080/readyz
# {"encryptionKey":"verified","expectedSchemaVersion":12,"schemaVersion":12,"status":"ready",...}
```

ENCRYPTION_KEY 는 개인정보·OIDC Secret·API 토큰을 암호화하는 32바이트 키(Base64 또는 64자리 hex)다.
openssl rand -base64 32 로 한 번 생성한 뒤 PostgreSQL 백업과 함께 별도 보관한다. 값을 잃거나 바꾸면 기존 암호화 데이터를 복구할 수 없다.

기동 시 서비스는 데이터베이스에 저장된 검증값을 복호화해 ENCRYPTION_KEY 가 그 데이터베이스의 키와 같은지 확인한다. 검증값이 없는 기존 데이터베이스는 이미 저장된 암호문 한 건으로 대신 확인한다. 키가 다르면 기동을 중단하므로 (로그 encryption key verification failed), 잘못된 키로 운영을 시작해 복구할 수 없는 데이터가 섞이는 일은 발생하지 않는다. 부트스트랩 관리자가 이미 있으면 환경 변수의 비밀번호로 덮어쓰지 않는다.

최초 관리자 로그인

http://host:8080 에 접속해 BOOTSTRAP_ADMIN / BOOTSTRAP_ADMIN_PASSWORD 로 로그인한다. 이 계정은 super_admin 이다. 로그인 후 순서대로 한다.

1. 관리자 → 시스템 설정 → 일반: 서비스 이름, 회사/조직명, **외부 기준 URL**(모바일 방문증·MMS QR 이미지 링크의 공개 주소, 예 `https://visit.company.intra`), 기본·지원 언어.
2. 조직 · 사업장: 사업장 주소·시간대(IANA), 로비, 조직. 시간대는 오늘 방문·통계·CSV·자동 퇴실의 날짜 기준이다.
3. 방문 · QR 정책, 개인정보, 보안 · 키 탭을 회사 정책에 맞춘다(3절).
4. 로컬 계정을 쓰면 조직 · 사업장 → 로컬 사용자 추가 , SSO를 쓰면 Keycloak SSO 탭(4절).

포트·볼륨·자원

항목	값
포트	컨테이너 8080/tcp 하나. compose.yaml 은 호스트 8080 에 매핑한다.
볼륨	없음. /tmp 만 tmpfs(128MB).
헬스체크	visitflow healthcheck (컨테이너 내부에서 GET /healthz) 30초 간격, 시작 유예 20초.
데이터베이스	PostgreSQL 14+. 기동 시 최대 2분 동안 연결을 재시도한다.
자원	유휴 시 메모리 수십 MB. CPU는 QR 생성·XLSX 파싱 순간에만 쓴다.

3. 설정

환경 변수 (전수)

internal/platform/config.go 가 읽는 변수는 아래 네 개가 전부다. 하나라도 비면 configuration error ... missing required environment variables: ... 로 종료한다.

이름	기본 값	필 수	설명
POSTGRES_DSN	없음	필 수	PostgreSQL 접속 문자열. 예 postgres://visitflow:CHANGE_ME@postgres.intra:5432/visitflow? sslmode=require
BOOTSTRAP_ADMIN	없음	필 수	최초 최고 관리자(super_admin) 아이디. 이미 있으면 건드리지 않는다.
BOOTSTRAP_ADMIN_PASSWORD	없음	필 수	최초 관리자 비밀번호. 12자 미만이면 기동 거부.
ENCRYPTION_KEY	없음	필 수	32바이트 키(Base64 또는 64자리 hex). 예 openssl rand -base64 32 출력.

시스템 설정 화면

나머지 운영 설정은 관리자 → 시스템 설정의 여덟 탭에 있으며 데이터베이스에 저장된다. 비밀값(Client Secret, Authorization Header, /metrics 토큰)은 ENCRYPTION_KEY 로 암호화되고 화면에서 마스킹된다. 모든 변경은 Before/After가 감사 로그에 남는다.

VF

VisitFlow
VISITOR OPERATIONS

개인 서비스

Dashboard

방문 신청

내 방문 일정

방문 템플릿

사용자 가이드

방문 승인

로비 서비스

Lobby Dashboard

QR Scan

현장 방문 등록

비상 대피 명단

관리자

관리 Dashboard

방문 · 방문자

현재 운영 버전

VisitFlow v2.7.3

시스템 설정

최고 관리자

SYSTEM CONTROL

시스템 설정

모든 변경 저장됨

배포 환경변수는 PostgreSQL DSN, Bootstrap 계정 2개와 Encryption Key뿐이며, 나머지 운영 설정은 여기에서 관리합니다.

Keycloak 비활성

승인 자동 확정

기존 알림 log

일반

Keycloak SSO

방문 · QR 정책

기존 알림 Adapter

메일 (SMTP)

개인정보

보안 · 키

서비스 이름

VisitFlow

회사/조직명

외부 기준 URL

모바일 방문증 및 MMS QR 이미지의 공개 기준 URL. 예: https://visit.company.intra

기본 언어

ko-KR

지원 언어

ko en

공백으로 구분. 예: ko en ja

설정 내보내기

설정 가져오기

설정 저장

비밀값 AES-256-GCM

변경 Before/After 감사 대상

콘텐츠 CDN 0개

시스템 설정 — 일반 탭. 서비스 이름, 외부 기준 URL, 기본·지원 언어

탭	설정
일반	서비스 이름, 회사/조직명, 외부 기준 URL, 기본 언어(ko , en , ja , zh), 지원 언어.
Keycloak SSO	Issuer URL, Client ID, Client Secret, 그룹 매핑, 연결 테스트, 활성화, Keycloak 세션이 있으면 자동 로그인, MCP를 Keycloak 토큰으로 열기(OAuth) (4절).
방문 · QR 정책	승인 사용, 회사명 필수, 초기 체크인 허용(분), 미방문 유예(분), 자동 퇴실 시각, QR 1회 사용, Dynamic QR 주기, 방문자 사전등록 사용·링크 유효 시간, 승인 지연 에스컬레이션 시간.
기존 알림 Adapter	log /Webhook 호환 설정(부록의 계약). 문자 API·발송 규칙은 별도 메뉴에 있다.
메일 (SMTP)	서버·포트·보안 방식(starttls / tls / none)·계정·발신자, TLS 인증서 검증 생략 , 테스트 메일 발송 , 로컬 계정 메일 비밀번호 재설정 .
개인정보	마스킹 시작 일수, 개인정보 파기 일수, 감사 보존 일수, 동의 정책 버전. 자주 방문자 주소록도 마지막 템플릿 사용 시점을 기준으로 같은 파기 기간을 적용한다.
방문 추적	방문 추적 사용(기본 꺼짐), Provider(momento · ga4 · gtm · matomo · custom), Momento 수집기 주소·사이트 ID·같은 오리진 프록시, 직접 입력 스니펫, 추가 허용 출처, 관리 화면 포함 여부, 삽입 위치, 정책이 차단한 출처 표(아래 방문 추적 스크립트).
보안 · 키	세션 유효 시간, 개인 API 키 허용 범위·만료·회전 유예·개수, 로그인 실패 허용 횟수와 잠금 시간, 공개 API 분당 요청 한도, 신뢰할 Reverse Proxy, Prometheus /metrics 토큰.

VF

VisitFlow

VISITOR OPERATIONS

개인 서비스

Dashboard

방문 신청

내 방문 일정

방문 템플릿

사용자 가이드

방문 승인

로비 서비스

Lobby Dashboard

QR Scan

현장 방문 등록

비상 대피 명단

관리자

관리 Dashboard

방문 · 방문자

현재 운영 버전

VisitFlow v2.7.3

시스템 설정

최고 관리자

SYSTEM CONTROL

시스템 설정

모든 변경 저장됨

Keycloak 비활성

승인 자동 확정

기존 알림 log

일반

Keycloak SSO

방문 · QR 정책

기존 알림 Adapter

메일 (SMTP)

개인정보

보안 · 키

방문 승인 Workflow

QR 1회 체크인

회사명 필수

방문자 셀프 사전등록

조기 체크인 허용 (분)

미방문 판정 유예 (분)

60

120

Dynamic QR 주기 (초)

자동 퇴실 처리 시각

0

23

0은 고정 서버 검증 QR, 권장 Dynamic 값은 30-60

승인 지연 에스컬레이션 (시간)

사전등록 링크 유효기간 (시간)

24

72

승인 대기가 이 시간을 넘으면 approval_escalated 알림 규칙이 한 번 발송됩니다.

설정 내보내기

설정 가져오기

설정 저장

비밀값 AES-256-GCM

변경 Before/After 감사 대상

원타임 CDN 0개

시스템 설정 — 방문 · QR 정책 탭. 승인 사용, 조기 체크인, 미방문 유예, 자동 퇴실, QR 정책

자동 퇴실 시각은 사업장별 현지 시각으로 판정하므로, 시간대가 다른 사업장은 각자의 저녁에 미퇴실 방문자를 정리한다. 승인 대기가 승인 지연 에스컬레이션 시간을 넘기면 approval_escalated 이벤트가 방문당 한 번 발생하므로 이 이벤트에 발송 규칙을 연결해 보안 담당자나 관리자에게 알릴 수 있다.

VF

VisitFlow

VISITOR OPERATIONS

시스템 설정

최고 관리자

a

개인 서비스

Dashboard

방문 신청

내 방문 일정

방문 템플릿

사용자 가이드

방문 승인

로버 서비스

Lobby Dashboard

QR Scan

현장 방문 등록

비상 대피 명단

관리자

관리 Dashboard

방문 · 방문자

현재 운영 버전

VisitFlow v2.7.3

SYSTEM CONTROL

시스템 설정

모든 변경 저장됨

Keycloak 비활성

승인 자동 확정

기존 알림 log

일반

Keycloak SSO

방문 · QR 정책

기존 알림 Adapter

메일 (SMTP)

개인정보

보안 · 키

세션 유효시간 (시간)

8

개인 키 기본 유효기간 (일)

90

키 회전 유효시간 (시간)

24

허용 개인 키 Scope

read write mcp

read write mcp 중 허용할 범위를 공백으로 구분합니다. 제거한 Scope는 기존 키에도 즉시 차단됩니다.

사용자별 활성 키 한도

10

로그인 실패 허용 횟수

5

IP와 계정 각각에 적용됩니다.

로그인 잠금 시간 (분)

15

공개 API 분당 요청 한도

60

모바일 방문증, QR 이미지, 사전등록, 로그인에 적용됩니다.

신뢰할 Reverse Proxy

리버스 프록시의 IP·CIDR을 공백으로 구분해 입력하면 X-Forwarded-For의 실제 접속 IP를 잠금·요청 한도·감사 로그에 사용합니다. 사내 대역 전체는 private 한 단어로 지정합니다. 비워두면 헤더를 무시합니다.

Prometheus /metrics 토콘

설정하기 전까지 /metrics 엔드포인트는 404를 반환합니다.

ENCRIPTION_KEY는 설정 화면에서 변경하지 않습니다. PostgreSQL 백업과 함께 안전하게 보관하고, 모든 노드에 동일한 32바이트 키를 주입하세요. 키가 달라지면 암호화된 개인정보와 Client Secret을 복호화할 수 없습니다.

시스템 설정 — 보안 · 키 탭, 세션·개인 키·로그인 잠금·요청 한도·신뢰할 Reverse Proxy·metrics 토콘

설정 이관

시스템 설정 하단의 **설정 내보내기** 는 비밀번호를 제외한 모든 설정을 JSON으로 받는다. 다른 설치본에서 **설정 가져오기** 로 읽으면 화면에 값이 채워지고 저장 시 일반 설정 변경과 같은 검증·감사가 적용된다. 비밀번호는 설치별 키로 암호화되므로 항상 새로 입력한다.

방문 추적 스크립트

시스템 설정 → 방문 추적 탭에서 페이지에 방문 추적 도구를 붙인다. **기본값은 꺼짐**이라 새로 설치한 곳은 아무것도 달라지지 않고, 켜기 전까지 `/momento/*` 경로도 404다. 설정은 데이터베이스에 있어 재배포 없이 화면에서 바꾼다.

설정	뜻
방문 추적 사용	켜야 스니펫이 붙는다. Provider가 없음 이거나 Provider에 필요한 값이 비어 있으면 저장이 거절된다.
Provider	Momento (사내 자체 호스팅 수집기 — 데이터가 밖으로 나가지 않는 유일한 선택지), Google Analytics 4, Google Tag Manager, Matomo, 직접 입력.
Momento 수집기 주소 · 사이트 ID · 환경	Momento 수집기의 http(s) 주소와 사이트 id, data-environment 값(기본 prd).
Momento 같은 오리진 프록시	기본 켜짐. 앱이 /momento/* 를 수집기로 넘기고 스니펫에 data-endpoint="/momento" 를 주므로 브라우저는 수집기 주소를 직접 부르지 않고 외부 출처가 정책에 아예 등장하지 않는다. 넘길 때 방문자의 세션 쿠키는 떼고 X-Forwarded-For 를 붙인다.
GA4 · GTM ID / Matomo 서버 주소 · 사이트 ID	각 도구의 id와 주소. 정책에 필요한 출처(googletagmanager.com , Matomo 서버)는 자동으로 더한다.
추적 코드 (직접 입력)	도구가 준 <script> 스니펫을 그대로 붙여 넣는다. 8KB를 넘으면 저장되지 않는다.
추가 허용 출처	스니펫에서 자동으로 읽지 못한 출처를 https://host 형태로 심표·줄바꿈으로 구분해 적는다. https://*.example.com 같은 와일드카드도 된다.
관리 화면(/admin)에 서도 추적	기본 꺼짐. 관리 화면 주소로 처음 열린 페이지에는 스니펫을 붙이지 않는다. 화면 안에서 메뉴로 이동하는 것은 새 페이지 요청이 아니므로, 관리자가 / 에서 시작해 /admin/... 으로 이동한 세션은 이미 붙은 스니펫이 그대로 남는다.
삽입 위치	head (</head> 앞) 또는 body (</body> 앞).

CSP를 어떻게 통과하는가. VisitFlow는 모든 응답에 script-src 'self' 로 잠긴 콘텐츠 보안 정책을 보낸다. 스니펫을 그냥 붙이면 브라우저가 조용히 막고 화면에는 아무 표시도 없다. 추적을 켜면 서버는 페이지를 낼 때마다 새 nonce를 만들어 스니펫의 모든 <script> 태그에 nonce="..." 로 달고 같은 값을 script-src 'nonce-...' 에 넣는다. 스니펫 문자열 안의 http(s)://host 출처(로더 주소, 수집 엔드포인트, 픽셀)는 자동으로 읽어 script-src · connect-src · img-src 에 더한다. 정책을 'unsafe-inline' 으로 푸는 일은 없다 — 한 번 풀면 앱의 모든 인라인 스크립트가 함께 허용되고 추적을 끈 뒤에도 느슨한 채 남기 때문이다. 추적을 끄면 정책은 원래의 좁은 정책으로 돌아간다. /api/* , /mcp , /healthz , /readyz , /metrics 에는 스니펫도 넓은 정책도 붙지 않는다.

차단된 출처를 보는 곳. 추적이 켜진 동안에만 정책에 report-uri /api/v1/tracking/csp-report 가 들어가고, 브라우저가 막은 요청을 이 경로로 신고한다(인증 없음, 본문 8KB 제한, 공개 API 요청 한도 적용). 서버는 출처와 지시어를 메모리에 최근 100개 출처만 같은 출처끼리 묶어 두므로 재시작하면 비워지고 노드가 여럿이면 각자 자기 것만 보여 준다. 방문 추적 탭 아래의 정책이 차단한 출처 표에서 허용 목록에 추가 를 누르면 그 출처가 추가 허용 출처 에 들어가고 설정 변경으로 감사 로그에 남는다. 이미 정책에 있는 출처는 허용됨 으로 표시되어, 스니펫을 고친 뒤 기록 비우기로 무엇이 아직 막히는지 확인할 수 있다.

붙이지 말아야 할 것. 로그인·모바일 방문증·사전등록·키오스크 화면에도 스니펫이 들어가므로 개인 식별 값을 보내는 코드는 넣지 않는다. QR 검증과 방문자 정보는 모두 API 응답으로 오가며 페이지 HTML에는 없다.

사업장·로비·조직과 방문 유형

VF

VisitFlow

VISITOR OPERATIONS

개인 서비스

Dashboard

방문 신청

내 방문 일정

방문 템플릿

사용자 가이드

방문 승인

로비 서비스

Lobby Dashboard

QR Scan

현장 방문 등록

비상 대피 명단

관리자

관리 Dashboard

방문 · 방문자

현재 운영 버전

VisitFlow v2.7.3

조직 · 사업장

최고 관리자

a

MASTER DATA

조직 · 사업장 · 권한

멀티 사업장과 로비, 조직 및 Keycloak 프로비저닝 사용자를 관리합니다.

사업장

+ 추가

본사 · Asia/Seoul

로비

+ 추가

1층 안내데스크 · 본사

조직

+ 추가

총무팀

사용자 · RBAC

Role, 소속 부서(부서 관리자 승인 범위), 담당 사업장(로비 담당자 범위)과 계정 활성 상태를 변경합니다. 최고 관리자 계정은 최고 관리자만 바꿀 수 있습니다.

로컬 사용자 추가

사용자	아이디	인증	Role	부서	담당 사업장	상태	최근 로그인	
admin	admin	LOCAL	super_admin		전체	비활성화	2026. 9. 11. 오후 9:30:34 세션 1개	비밀번호 초기화
로비 담당자	lobby01	LOCAL	lobby		본사	비활성화	-	비밀번호 초기화 (임시 비밀번호)

조직 · 사업장 · 권한 — 사업장·로비·조직 마스터와 사용자 · RBAC 표

조직 · 사업장에서 사업장(코드·이름·주소·시간대), 로비(사업장별), 조직(부서)을 등록하고 항목을 클릭해 수정한다.

VF

VisitFlow

VISITOR OPERATIONS

개인 서비스

Dashboard

방문 신청

내 방문 일정

방문 템플릿

사용자 가이드

방문 승인

로비 서비스

Lobby Dashboard

QR Scan

현장 방문 등록

비상 대피 명단

관리자

관리 Dashboard

방문 · 방문자

현재 운영 버전

VisitFlow v2.7.3

방문 유형 · 키오스크

최고 관리자

a

SITE POLICY

방문 유형 · 키오스크

방문 유형별 필수 확인 항목과 무인 로비 태블릿 기기를 관리합니다.

방문 유형 · 체크리스트

+ 유형 추가

보안서약, 안전교육, 차량·장비 신고와 승인 강제를 유형별로 지정합니다.

코드	이름	필수 확인	승인	상태	관리
GENERAL	일반 방문 회의·상담 등 일반 업무 방문		-	사용	수정 중지
CONTRACTOR	협력사 작업 현장 작업·설비 점검. 보안서약과 안전교육 확인이 필요합니다.	보안서약 안전교육	필수	사용	수정 중지

로비 키오스크 기기

+ 기기 등록

기기 토큰은 로비 API에만 접근하며 발급 시 한 번만 표시됩니다.

기기	사업장 · 로비	토큰	만료	최근 사용	상태	관리
본관 로비 태블릿	본사 · 1층 안내데스크	vfk_hK0FzJ8B...	2026. 10. 11.	-	사용	폐기

방문 유형 · 키오스크 — 유형별 보안서약·안전교육·차량·반입 장비 필수 여부와 승인 강제, 로비 키오스크 기기

방문 유형에는 코드, 이름, 설명과 함께 보안서약 확인, 안전교육 이수 확인, 차량번호 신고, 반입 장비 신고, 승인 강제를 지정한다. 신청 화면은 선택한 유형이 요구하는 항목을 채우지 않으면 제출을 막고, 승인 강제 유형은 전역 승인 정책이 꺼져 있어도 승인 대기로 들어간다. 사용하지 않는 유형은 중지 하며 과거 기록의 유형 정보는 유지된다. 기본으로 GENERAL (일반 방문)과 CONTRACTOR (협력사 작업, 보안서약·안전교육·승인 필수)가 들어 있다.

같은 화면의 로비 키오스크 기기에서 기기 이름, 사업장, 로비, 유효기간을 지정해 기기 토큰을 발급한다. 태블릿에서 발급 링크를 한 번 열면 등록이 끝나고 이후 로그인 없이 로비 화면만 쓴다. 기기 토큰은 로비 API에만 접근할 수 있어 개인·관리자·감사 화면에는 도달하지 못하며, 목록에서 즉시 폐기할 수 있다.

문자 API와 발송 규칙

VF

VisitFlow

VISITOR OPERATIONS

개인 서비스

Dashboard

방문 신청

내 방문 일정

방문 템플릿

사용자 가이드

방문 승인

로비 서비스

Lobby Dashboard

QR Scan

현장 방문 등록

비상 대피 명단

관리자

관리 Dashboard

방문 · 방문자

현재 운영 버전

VisitFlow v2.7.3

문자 API · 발송 규칙

최고 관리자

MESSAGE INTEGRATION

문자 API · 발송 규칙

SMS, MMS, 카카오톡 API의 URL-path-parameter와 방문 흐름별 발송 시점을 관리합니다.

외부 시스템 연동 채널과 외부 시스템 수신 대상을 조합하면 같은 화면에서 출입 게이트나 게스트 Wi-Fi 발급 API를 호출할 수 있습니다. 방문자 언어를 지정하면 언어별 템플릿을 나란히 운영할 수 있습니다.

API를 선택하지 않은 규칙은 시스템 설정의 기존 log/webhook Adapter를 사용합니다. 활성 API에는 중복 방지용 {{idempotencyKey}} 또는 {{notificationId}}가 필요합니다. MMS Gateway가 QR을 가져가려면 Parameter에 {{qrcodeUrl}}을 연결하고 외부 기준 URL을 설정하세요.

호출 API

채널마다 여러 API를 등록할 수 있으며 URL과 path를 별도로 조합합니다.

이름

채널

호출 주소

방식

상태

관리

데모 문자 Gateway

SMS

https://sms.example.com/v1/send

POST · json

사용

테스트 발송

수정

삭제

발송 시점 · 규칙

각 시점에서 수신 대상, 채널, 호출 API와 메시지 템플릿을 선택합니다.

규칙

시점

수신

언어

채널 · API

템플릿

상태

관리

체크인 시 담당자 도착 안내

체크인 시

담당자

모든 언어

SMS · 기존 Adapter

host_arrival

사용

수정

삭제

방문 확정 시 방문증 안내

방문 확정 시

방문자

모든 언어

SMS · 기존 Adapter

visitor_pass

사용

수정

삭제

문자 API · 발송 규칙 — Gateway 목록과 이벤트별 발송 규칙

관리자 → 문자 API · 발송 규칙에서 Gateway를 여러 개 등록한다. 각 API는 채널(sms , mms , kakao), Base URL, Path, HTTP Method, 요청 형식(json , form , query), Header와 Parameter Template을 독립적으로 가진다. Header와 Parameter는 암호화 저장되며 secretKeys 로 지정한 값은 조회 화면에서 마스킹된다. 테스트 발송 은 수신 번호를 지정해 실제 API를 한 번 호출하고 소요 시간·게이트웨이 메시지 ID·오류를 표시하며 감사 로그에 남긴다.

Parameter 값에서는 {{recipient}}, {{message}}, {{notificationId}}, {{idempotencyKey}}, {{visitId}}, {{visitor}}, {{company}}, {{start}}, {{place}}, {{passUrl}}, {{qrcodePath}}, {{qrcodeUrl}} 같은 발송 문맥 변수를 쓴다. MMS 이미지 Parameter에 {{qrcodeUrl}} 을 지정하면 외부 기준 URL을 포함한 주소가, {{qrcodePath}} 에는 /img/visitor/{{qrcode_file_seq}}.jpg 상대 경로가 전달된다. 외부 Gateway가 QR 이미지를 가져가려면 일반 설정의 외부 기준 URL이 Gateway에서 접근 가능한 HTTPS 주소여야 한다.

활성 API는 Header 또는 Parameter에 {{idempotencyKey}} 나 {{notificationId}} 중 하나를 반드시 전달해야 한다. 같은 알림 ID로 재시도해도 중복 발송하지 않도록 Gateway도 이 값을 멍등성 키로 처리해야 한다. API를 중지하면 연결된 활성 규칙도 중지되고 아직 발송되지 않은 대기 건은 취소된다.

발송 규칙은 방문 확정, 방문 시작, 체크인, 퇴실, 방문 취소, 방문 반려, 승인 지연 중 하나를 선택하고 방문자/담당자 수신 대상, 분 단위 오프셋, 메시지 Template과 호출 API를 연결한다. 방문 시작 규칙은 음수 오프셋으로 사전 알림을 예약할 수 있고, 나머지 이벤트는 0 이상의 지연 발송을 쓴다. 방문 시작 규칙을 바꾸면 기존 예약 건도 수신자·채널·API·본문·시각을 한 묶음으로 다시 계산한다. 다른 이벤트의 큐 정책을 바꾸거나 규칙을 중지하면 기존 대기 건을 취소하고 다음 이벤트부터 새 설정을 적용한다.

- 채널을 이메일 (SMTP) 로 두면 문자 API 대신 시스템 설정의 SMTP로 발송한다. 수신자는 방문자 또는 담당자(대리 지정 중이면 대리자)의 이메일이고 주소가 없으면 그 방문자에게는 만들어지지 않는다. 메일 제목 템플릿은 본문과 같은 변수를 쓰며 비우면 [VisitFlow] 방문 안내 {{requestNo}} 가 된다. 방문 확정 시 {{passUrl}} 을 본문에 넣으면 모바일 방문증 링크가 메일로 간다.
- 규칙에 방문자 언어를 지정하면 그 언어를 선택한 방문자에게만 발송되므로 같은 이벤트에 한국어와 영어 템플릿을 나란히 둘 수 있다. 언어를 지정하지 않은 규칙은 모든 방문자에게 적용된다.
- 수신 대상 외부 시스템 과 채널 외부 시스템 연동 을 조합하면 출입 게이트, 게스트 Wi-Fi 발급 같은 사내 API를 같은 화면에서 호출한다. 이때 {{recipient}} 에는 전화번호 대신 방문자 참가 ID가 전달되며 호출할 API를 반드시 선택해야 한다.

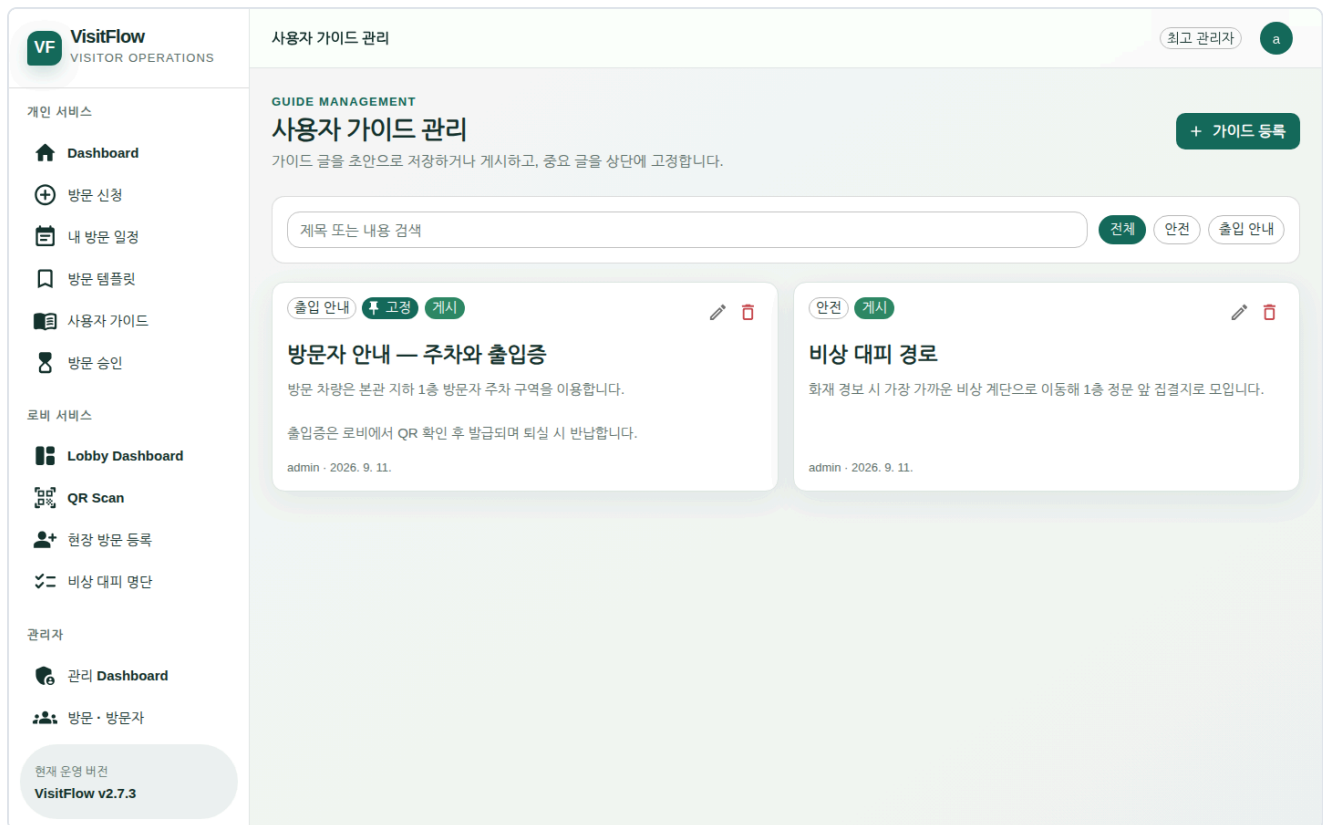
사내 SMTP 메일

시스템 설정 → 메일 (SMTP)에서 서버, 포트, 보안 방식, 계정, 발신자를 입력하고 SMTP 메일 발송 사용 을 켜다. 인증은 TLS 위에서 PLAIN, 그 외 LOGIN·CRAM-MD5를 서버가 광고하는 순서대로 자동 선택하므로 Exchange 계열도 그대로 연결된다. 사설 인증서를 쓰는 릴레이는 TLS 인증서 검증 생략 을 켤 수 있다. 테스트 메일 발송 은 저장된 설정으로 실제 메일을 보내고 결과·소요 시간을 표시하며 감사 로그에 남긴다.

SMTP가 켜지면 세 기능이 동작한다.

- **승인 대기 알림:** 방문은 담당자의 소속 부서를 물려받는다. 부서가 지정된 방문은 그 부서의 부서 관리자(및 대리자)에게, 담당자에게 부서가 없어 방문에도 부서가 없는 경우에는 어디서나 승인할 수 있는 보안 담당자·관리자에게 전달된다.
- **메일 알림:** 담당자와 승인자가 프로필 메뉴에서 받을 이벤트를 직접 고른다. 계정에 이메일이 있어야 하며 대리 담당자도 같은 기준으로 받는다. 발송은 문자와 같은 알림 큐(email 채널)를 지나므로 재시도·이력·수동 재시도가 동일하게 적용된다.
- **비밀번호 재설정 메일:** 로컬(비 SSO) 계정은 로그인 화면의 비밀번호를 잊으셨나요? 에서 아이디 또는 이메일로 재설정 링크를 요청한다. 응답은 계정 존재 여부와 무관하게 동일하고 IP·식별자별로 제한된다. 링크는 설정한 시간 동안 한 번만 유효하며 사용 시 모든 세션이 종료된다. 관리자의 비밀번호 초기화 에서도 임시 비밀번호 대신 재설정 링크를 메일로 발송 을 선택할 수 있다. 로컬 계정 메일 비밀번호 재설정 스위치로 끌 수 있다.

사용자 가이드 게시판



사용자 가이드 관리 — 제목·분류·본문을 등록하고 초안/게시·상단 고정을 바꾼다

관리자 → 사용자 가이드 관리에서 제목, 분류와 본문을 등록한다. 초안은 관리자에게만 보이고 게시 상태로 바꾼 글만 로그인 사용자에게 노출된다. 자주 확인해야 하는 글은 상단 고정할 수 있으며 수정·게시·삭제는 감사 로그에 기록된다.

4. 계정과 권한

역할

역할은 `internal/app/types.go` 의 헬퍼가 정한다. 화면에는 오른쪽 위 칩에 한국어 이름으로 표시된다.

Role	화면 이름	할 수 있는 일
user	방문 요청자	방문 신청·수정·취소, 내 방문 일정, 템플릿, 사전등록 링크, 프로필·개인 API 키.
lobby	로비 담당자	위 + Lobby Dashboard, QR Scan, 현장 방문 등록, 비상 대피 명단. 담당 사업장 이 지정되면 그 사업장의 로비·방문증만 처리한다.
dept_manager	부서 관리자	위(user) + 소속 부서 방문의 승인·반려. 대리자를 지정하면 그 부서의 승인 대기를 대리자가 처리한다.
security	보안 담당자	로비 담당자 권한 + 전체 방문 승인·반려, 방문 · Watch List 관리, 감사 로그 열람.
auditor	감사 담당자	user + Audit Log 열람과 CSV 내보내기.
admin	서비스 관리자	관리자 메뉴 전부: 관리 Dashboard, 방문 · 방문자, 조직 · 사업장, 통계 · 알림, 문자 API · 발송 규칙, 방문 유형 · 키오스크, 사용자 가이드 관리, Audit Log, 시스템 설정, API / MCP. super_admin 계정은 만들거나 바꿀 수 없다.
super_admin	최고 관리자	admin 전부 + 최고 관리자 계정 부여·변경. 마지막 최고 관리자는 권한을 낮추거나 비활성화할 수 없다(last_super_admin).

로컬 사용자와 RBAC 표

Keycloak을 쓰지 않는 환경에서는 조직 · 사업장 · 권한 → 로컬 사용자 추가 로 계정을 만든다(위 화면). 임시 비밀번호 호가 한 번만 표시되고, 사용자는 첫 로그인에서 새 비밀번호로 바꿔야 다른 기능을 쓸 수 있다(서버가 변경 전 모든 API 를 403 password_change_required 로 차단). 사용자 · RBAC 표에서 Role과 함께 소속 부서(부서 관리자의 승인 범위)와 담당 사업장(로비 담당자의 조회·체크인 범위)을 바로 지정한다.

- 비밀번호 초기화 는 새 임시 비밀번호를 발급하며 그 계정의 모든 세션을 종료하고 로그인 잠금도 해제한다.
SMTP가 켜져 있으면 재설정 링크를 메일로 발송 을 대신 고를 수 있다.
- 세션 종료 는 퇴직·유출 의심 시 모든 세션과 개인 API 키를 즉시 폐기한다.
- 비활성화 된 계정은 로그인할 수 없다. 일반 사용자는 프로필 메뉴에서 스스로 비밀번호를 바꿀 수 있다.

Keycloak SSO

- 시스템 설정 → Keycloak SSO에서 Issuer URL , Client ID , Client Secret 을 입력한다.
- Keycloak Client의 Client authentication을 켜다.

3. Valid Redirect URI에 `https://서비스주소/api/v1/auth/oidc/callback` 을 등록한다.
4. Group Membership mapper로 `groups claim`을 ID Token에 포함한다.
5. 필요하면 `/visitflow-admins` , `/visitflow-lobby` , `/visitflow-security` , `/visitflow-auditors` ,
`/visitflow-department-managers` 를 사내 그룹명으로 바꾼다.
6. 저장 후 연결 테스트를 실행하고 SSO를 활성화한다.

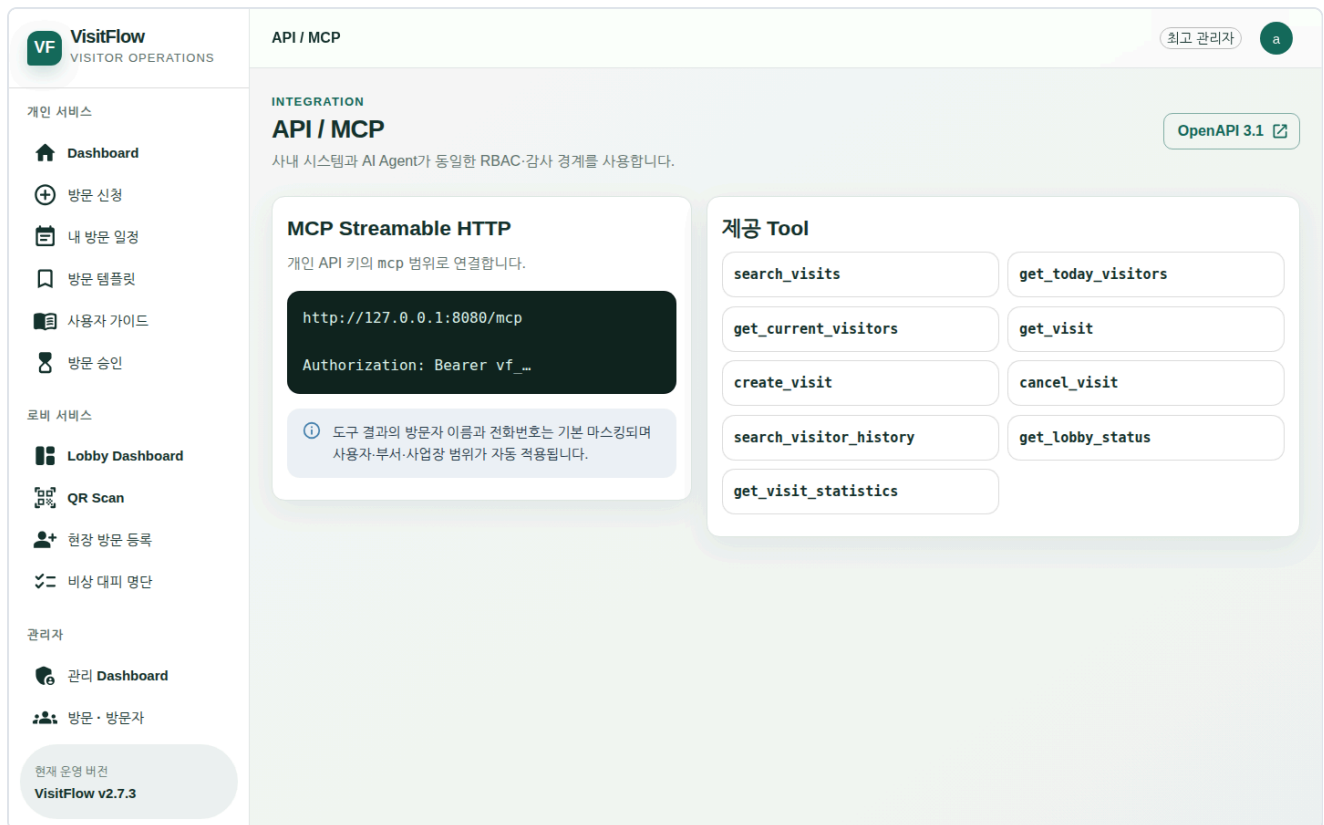
Issuer의 표준 Discovery 문서에서 Authorization/Token/JWKS Endpoint가 자동 구성되며 state, nonce, PKCE S256과 ID Token 서명을 검증한다. 등록되지 않은 사용자의 SSO 로그인을 막으면 등록된 사용자만 SSO로 로그인할 수 있습니다 (403 `oidc_provision_disabled`)가 표시된다. SSO 사용자의 비밀번호는 Keycloak에서 바꾼다.

자동 로그인 (Silent SSO)

Keycloak 세션이 있으면 자동 로그인 (`oidc.auto_login` , 기본값 꺼짐)을 켜면 Keycloak에 이미 로그인한 사람이 VisitFlow를 열었을 때 로그인 화면을 거치지 않고 바로 본 화면으로 들어간다. 다른 사내 서비스와 SSO를 공유하는 환경에서 켜다. 기본 설치에서는 꺼져 있어 아무것도 달라지지 않는다.

- **동작:** 세션이 없는 브라우저가 보호된 화면을 열면 Keycloak으로 `prompt=none` 요청을 보낸다. 이 요청은 화면을 그리지 않는다 — Keycloak 세션이 있으면 인가 코드가 바로 돌아와 평소처럼 로그인되고, 없으면 `login_required` 로 돌아온다. 후자는 실패가 아니라 평범한 대답이며, 로그인 화면을 보여 준다. 숨은 `iframe`이 아니라 최상위 페이지 이동이라 서드파티 쿠키가 막힌 브라우저에서도 동작한다.
- **한 번만 시도:** 브라우저는 한 탭 세션에 한 번만 시도한다(`sessionStorage`). 거절당한 뒤 새로고침해도 다시 시도하지 않고, 새 탭에서는 다시 시도한다. 거절된 시도는 `/login?sso=none` 으로 돌아오며 그 주소에서도 다시 시도하지 않는다. 사생활 보호 모드처럼 저장소를 읽지 못하는 브라우저는 "이미 시도했다"로 간주해 시도하지 않는다. 그래서 Keycloak에 로그인하지 않은 사용자도 화면이 깜빡이거나 리다이렉트가 반복되지 않는다.
- **로그아웃 뒤에는 시도하지 않는다:** 스스로 로그아웃하면 그 탭에서는 다시 로그인할 때까지 자동 로그인을 억제한다.
- **시도하지 않는 자리:** 로그인 화면, SSO 콜백, 방문증(`/q/...`)·사전등록(`/r/...`)·키오스크·비밀번호 재설정 같은 방문자용 화면, API·MCP·헬스 경로에서는 시도하지 않는다. 로그인이 필요한 화면을 브라우저로 열었을 때만 해당한다.
- **깊은 링크:** `/admin/visits?status=PENDING` 같은 주소로 들어온 사람은 조용히 로그인한 뒤 그 자리로 돌아온다. 돌아갈 주소는 `/` 로 시작하고 `//` 로 시작하지 않는 같은 사이트 경로만 받는다.
- **서버가 강제한다:** 설정이 꺼져 있으면 누군가 주소에 `?prompt=none` 을 붙여 `/api/v1/auth/oidc/start` 를 열어도 서버가 조용히 평범한 로그인으로 바꾼다. GET `/api/v1/auth/config` 의 `oidcAutoLogin` 은 SSO와 이 설정이 모두 켜져 있을 때만 `true` 다.
- **Keycloak 쪽 준비:** 별도 설정은 없다. `prompt=none` 은 표준 OIDC 파라미터이며 Valid Redirect URI만 3절대로 등록돼 있으면 된다.

개인 API 키와 MCP



API / MCP — OpenAPI·MCP 엔드포인트와 도구 목록, 관리자가 허용한 키 범위

보안 · 키 탭에서 허용 범위(`read` , `write` , `mcp`), 만료, 회전 유예, 활성 키 개수를 정하면 사용자가 프로필 → 내 API 키에서 그 범위 안에서 키를 만든다. 원문은 서버에 저장하지 않으므로 복구할 수 없고 회전으로만 교체한다. 도구별 Role·Scope는 [API](#) 및 [MCP](#)를 본다.

키 없이 SSO로 MCP 연결 (OAuth)

MCP 인가 규격(2025-06-18 이후)은 OAuth 2.1이다. 이 기능을 켜면 MCP 클라이언트(Claude, Cursor 등)에 개인 키 대신 **URL 하나**만 주면 클라이언트가 스스로 Keycloak 로그인을 띄우고 액세스 토큰을 받아 `/mcp`에 붙인다. 개인 키는 그대로 동작하며, 키가 없는 자동화 스크립트나 폐쇄망은 계속 키를 쓴다. 기본값은 꺼짐이라 새로 설치한 곳은 아무 것도 달라지지 않는다.

VisitFlow는 **리소스 서버**다 — 로그인은 Keycloak이 하고 VisitFlow는 토큰을 검사만 한다. `/authorize` · `/token` · 동적 클라이언트 등록은 없고, 토큰을 저장하거나 세션으로 바꾸지 않으며 요청마다 검사한다. 토큰으로 계정을 만들지 않고, 정지된 계정을 열지 않으며, 토큰의 role claim으로 권한을 올리지 않는다. OAuth 토큰은 `/mcp`에서만 받는다 — REST·관리 API는 지금처럼 키와 세션만 받는다.

설정 (시스템 설정 → Keycloak SSO 탭, 아래쪽 카드)

키	기본값	뜻
<code>mcp.oauth.enabled</code>	<code>false</code>	켜기 스위치. Keycloak Issuer URL이 비어 있으면 저장이 거부된다 (<code>mcp_oauth_incomplete</code>).
<code>mcp.oauth.resource</code>	빈 값	리소스 식별자. 비우면 일반 → 외부 기준 URL + <code>/mcp</code> , 그것도 비면 요청의 Host로 만든다(마지막 수단 — 프록시 뒤라면 외부 기준 URL을 반드시 채운다). 채울 때는 클라이언트가 실제로 접속하는 공개 HTTPS 주소에 <code>/mcp</code> 를 붙인 값이어야 한다.
<code>mcp.oauth.audience</code>	빈 값	공백 구분 허용 대상. 토큰의 <code>aud</code> 또는 <code>azp</code> 가 이 목록에 있으면 이 서버용 토큰으로 본다(Audience 매퍼 없이 쓰는 호환 경로).
<code>mcp.oauth.scopes</code>	<code>read mcp</code>	SSO로 들어온 사용자에게 주는 범위. <code>mcp</code> 는 필수이며, 보안 · 키 탭의 허용 개인 키 Scope를 넘지 않는다. 토큰의 <code>scope</code> 에 <code>read · write · mcp</code> 가 실려 오면 그 교집합만 준다.
(재사용) <code>oidc.issuer_url</code> · <code>oidc.client_id</code>	Keycloak SSO 설정	발급자와 웹 로그인 클라이언트. 웹 클라이언트에 발급된 토큰은 항상 이 앱의 것으로 본다.

카드에는 MCP URL과 메타데이터 주소가 복사 버튼과 함께 표시된다. 사용자는 프로필 → 내 API 키 화면 아래의 "키 없이 SSO로 연결하기" 안내에서 같은 URL을 본다.

Keycloak 쪽 할 일

1. MCP 클라이언트용 **공개(public) 클라이언트**를 만든다(예: `claude-mcp`). Client authentication 끄, Standard Flow 컴, PKCE Method `s256` , Direct Access Grants·Implicit·Service accounts 끄. 웹 로그인 클라이언트 (`oidc.client_id`)와 **다른** 클라이언트다.
2. Valid Redirect URIs에 쓰는 MCP 클라이언트의 콜백을 정확히 적는다 — Claude는 `https://claude.ai/api/mcp/auth_callback` , 로컬 클라이언트는 `http://127.0.0.1:*/callback` 류. * 하나로 다 여는 것은 금지.
3. 대상 바인딩은 둘 중 하나:
 - **정식 경로** — 그 클라이언트(또는 전용 client scope)에 Audience 매퍼: Mapper type `Audience` , Included Custom Audience = 리소스 식별자(예 `https://visit.company.intra/mcp`), Add to access token 컴, Add to ID token 끄.
 - **호환 경로** — 매퍼 없이 이 앱의 `mcp.oauth.audience` 에 클라이언트 ID(`claude-mcp`)를 적는다. 실제 Keycloak 26은 `aud` 에 `account` 만 싣고 클라이언트 ID는 `azp` 에 담으므로 이 경로가 가장 빠르다.
4. (선택) 클라이언트가 메타데이터의 `scopes_supported` (`read mcp`)를 그대로 요청하면 Keycloak은 모르는 scope를 `invalid_scope` 로 거부할 수 있다. 그럴 때는 realm에 `read · mcp` 이름의 Client scope를 만들어 그 클라이언트의 Optional scope로 붙인다. 붙이면 토큰의 `scope` 에 실려 오고 VisitFlow는 관리자 범위와의 교집합만 준다.
5. 액세스 토큰 수명은 짧게(5분 안팎). VisitFlow는 introspection을 하지 않으므로 Keycloak에서 로그아웃하거나 사용자를 비활성화해도 **이미 발급된 토큰은 만료까지 산다** — 즉시 끊어야 하면 VisitFlow 쪽에서 계정을 비활성화 한다(계정 조회는 요청마다 한다).

확인 (curl)

```
# 1. 메타데이터 — 인증 없이 맨 JSON. 꺼져 있으면 404.
curl -s https://visit.company.intra/.well-known/oauth-protected-resource/mcp
# {"resource":"https://visit.company.intra/mcp","authorization_servers":["https://keycloak.intra/realms/com
# "bearer_methods_supported":["header"],"scopes_supported":["read","mcp"],"resource_name":"VisitFlow MCP"}

# 2. 토큰 없는 /mcp 는 401 과 함께 어디로 가야 하는지 알려 준다. REST 401 에는 이 헤더가 없다.
curl -si -X POST https://visit.company.intra/mcp -H 'Content-Type: application/json' \
  -d '{"jsonrpc":"2.0","id":1,"method":"tools/list"}' | grep -i www-authenticate
# WWW-Authenticate: Bearer realm="VisitFlow", resource_metadata="https://visit.company.intra/.well-known/oa

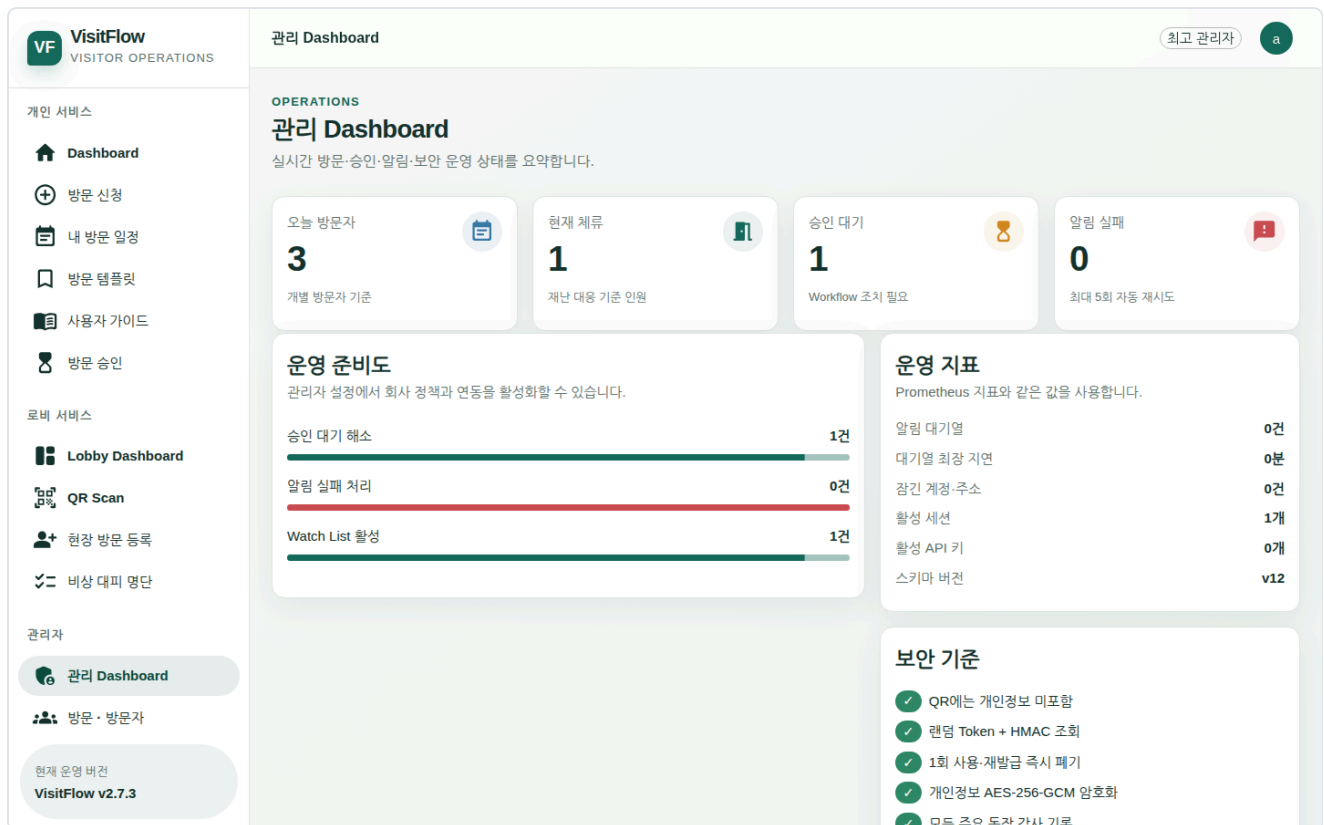
# 3. Keycloak 에서 받은 액세스 토큰으로 tools/list
curl -s -X POST https://visit.company.intra/mcp -H "Authorization: Bearer $TOKEN" -H 'Content-Type: applica
  -d '{"jsonrpc":"2.0","id":1,"method":"tools/list"}'
```

거부 메시지별 조치 — 클라이언트에는 아래 메시지가, 서버 로그에는 `mcp oauth token refused` 와 함께 어느 검사가 실패했는지(`cause=` : 서명·발급자·만료·nbf·대상·계정)가 남는다.

응답	뜻	조치
404 mcp_oauth_disabled (메타데이터)	스위치가 꺼져 있거나 Issuer가 비어 있다	Keycloak SSO 탭에서 켜고 Issuer URL을 채운다. 로그 mcp oauth is enabled but oidc.issuer_url is empty 도 같은 뜻이다.
401 authentication_required (토큰을 보냈는데)	꺼져 있어 토큰이 키퍼럼 취급됐다	위와 같다. 켜져 있지 않은 설치는 토큰에 대해 아무 말도 하지 않는다.
401 invalid_token ...유효하지 않습니다(서명 · 발급자 · 만료)	서명 검증 실패, 다른 realm, 만료, 아직 유효하지 않음(nbf), HS256·none 알고리즘	로그의 cause 를 본다. 다른 realm이면 Issuer URL을, 만료면 클라이언트에서 다시 로그인한다.
401 invalid_token ID 토큰은 MCP 자격이 아닙니다	클라이언트가 액세스 토큰 대신 ID 토큰을 보냈다	클라이언트 설정을 확인한다.
401 invalid_token ...이 서버를 위해 발급된 것이 아닙니다(aud=[account], azp="claude-mcp")	다른 앱용 토큰이거나 대상 바인딩이 아직 없다	메시지가 말하는 대로 mcp.oauth.audience 에 그 azp 를 적거나 Audience 매퍼에 리소스 식별자를 넣는다. 리소스 식별자가 메타데이터의 resource 와 같은지 본다.
401 account_not_registered	토큰의 sub (또는 preferred_username)에 해당하는 활성 계정이 없다	그 사용자가 웹으로 한 번 로그인한다(SSO 사용자 자동 생성 이 꺼져 있으면 관리자가 먼저 등록). 비활성 계정은 사용자 · RBAC에서 다시 활성화한다.
401 oidc_discovery_failed	Keycloak Discovery/JWKS를 읽지 못했다	네트워크·Issuer URL을 본다. 실패는 5초 동안 기억했다가 다시 시도한다.
403 insufficient_scope	유효 범위에 mcp 가 없다	mcp.oauth.scopes 와 허용 개인 키 Scope에 mcp 가 있는지, 토큰의 scope 가 read 만 싣고 있지 않은지 본다.

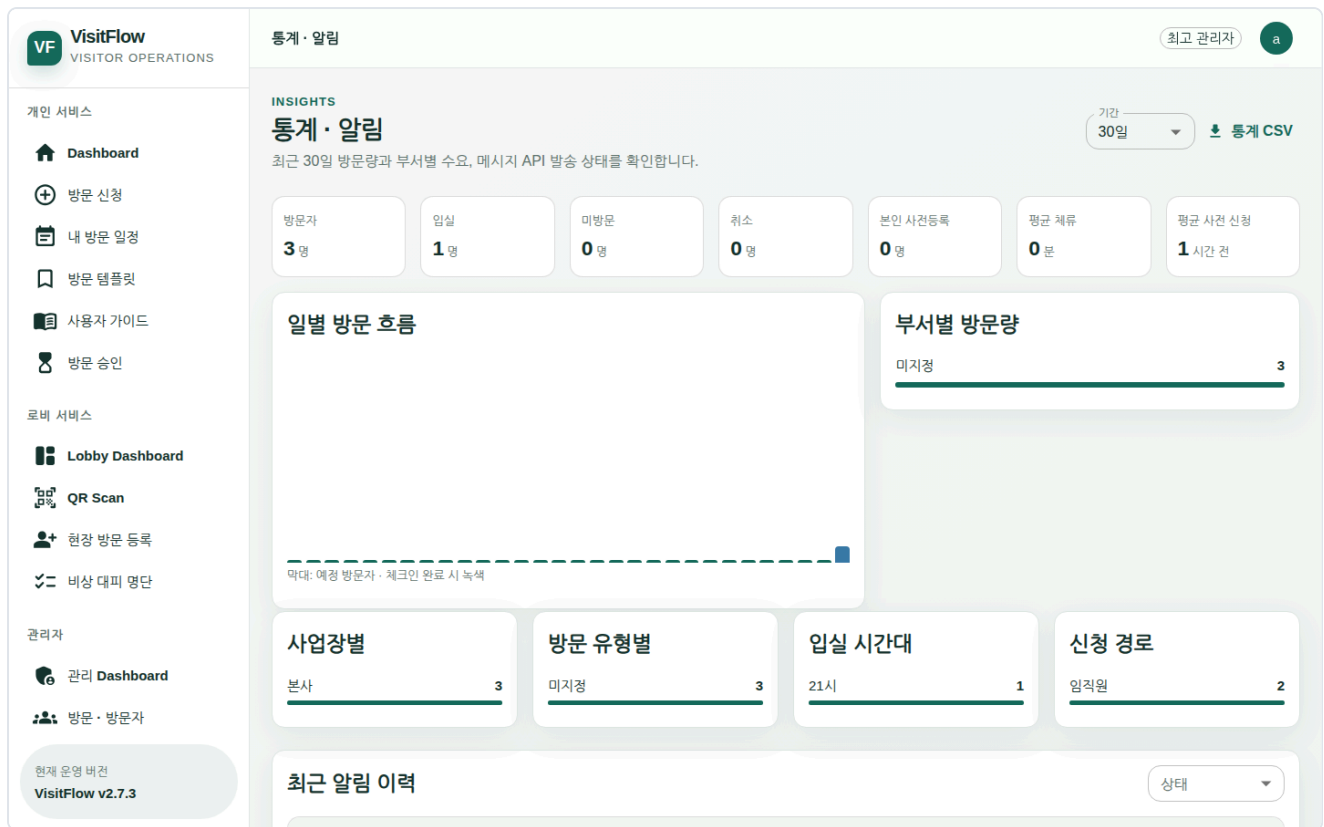
5. 운영

관리 Dashboard와 통계



관리 Dashboard — 오늘 방문자·현재 체류·승인 대기·알림 실패 타일, 운영 준비도, Prometheus와 같은 운영 지표

운영 지표 카드는 알림 대기열, 대기열 최장 지연, 잠긴 계정·주소, 활성 세션·API 키, 스키마 버전을 보여 준다. 같은 값을 Prometheus로 수집하려면 보안 · 키 탭에서 Prometheus /metrics 토큰 을 설정한 뒤 Authorization: Bearer < 토큰> 으로 GET /metrics 를 호출한다. 토큰을 설정하기 전까지 이 엔드포인트는 404를 반환한다.



통계·알림 — 기간별 방문 추이, 사업장·방문 유형·입실 시간대·신청 경로 분포, 알림 큐

통계·알림은 7일·30일·90일·1년 기간을 선택할 수 있고 사업장별·방문 유형별·입실 시간대·신청 경로 분포와 방문자 수, 입실·미방문·취소, 본인 사전등록 건수, 평균 체류 시간, 평균 사전 신청 시간을 보여 준다. 모든 집계와 CSV는 사업장 시간대 기준 날짜로 센다. 같은 화면에서 실패한 알림을 건별 재시도, 실패 일괄 재시도, 대기 건 취소할 수 있다. 재시도는 시도 횟수를 초기화하며, 연결된 API나 규칙이 중지된 알림은 이유를 표시하고 재시도를 거부한다.

방문·방문자 관리와 Watch List

VF

VisitFlow

VISITOR OPERATIONS

방문 · 방문자

최고 관리자 a

개인 서비스

Dashboard

방문 신청

내 방문 일정

방문 템플릿

사용자 가이드

방문 승인

로비 서비스

Lobby Dashboard

QR Scan

현장 방문 등록

비상 대피 명단

관리자

관리 Dashboard

방문 · 방문자

현재 운영 버전

VisitFlow v2.7.3

VISITOR CONTROL

방문 · 방문자 관리

방문 이력 CSV

전체 방문 방문자 이력 Watch List 방문번호 / 회사 / 담당자 / 방문자 이름·전화 검색 후 Enter

일시 / 번호	방문자	담당 / 장소	상태	승인
2026. 9. 13. 오후 11:00:00 VF-260913-ZRQ8GI	최지우 데모엔지니어링	admin 본사 · 1층 안내데스크 · 협력사 작업	승인 대기	반려 승인
2026. 9. 12. 오후 11:00:00 VF-260912-PK0B0C	박민수 데모테크	admin 본사 · 1층 안내데스크	방문 예정	
2026. 9. 11. 오후 11:00:00 VF-260911-NNLBCM	이철수 개인	admin 본사 · 1층 안내데스크	방문 예정	
2026. 9. 11. 오후 9:00:00 VF-260911-V05IEV	홍길동 외 1명 데모물산	admin 본사 · 1층 안내데스크	방문 중	

방문 · 방문자 — 방문 목록 검색, 방문자 이력, Watch List

방문 · 방문자에서 방문번호·회사·담당자·방문자 이름/전화로 방문을 찾고, 방문자 이력에서 방문자를 클릭하면 방문 목록과 동의 기록(주체·정책 버전)을 본다. 정보 주체의 삭제 요청은 즉시 파기 로 처리한다 — 요청 근거를 입력하면 이름·연락처·이메일·차량번호가 복구 불가능하게 대체되고, 담당자 주소록의 동일 방문자도 삭제되며, 감사 로그에 근거가 남는다. 진행 중이거나 예정된 방문이 있으면 먼저 종료해야 한다.

Watch List에는 전화번호 또는 회사명과 사유, 선택적 종료 시각을 등록한다. 해당 방문자가 포함된 신청은 보안 정책에 따라 방문 등록을 완료할 수 없습니다 로 막히고 watchlist.match 감사 이벤트가 남는다. 셀프 사전등록에서 방문자가 입력한 회사명도 다시 검사한다.

감사 로그와 내보내기

VF

VisitFlow

VISITOR OPERATIONS

개인 서비스

Dashboard

방문 신청

내 방문 일정

방문 템플릿

사용자 가이드

방문 승인

로비 서비스

Lobby Dashboard

QR Scan

현장 방문 등록

비상 대피 명단

관리자

관리 Dashboard

방문 · 방문자

현재 운영 버전

VisitFlow v2.7.3

Audit Log

최고 관리자

IMMUTABLE TRAIL

Audit Log

로그인, 개인정보 조회, QR 검증과 모든 운영 변경을 추적합니다.

감사 로그 CSV

이벤트 접두어

행위자

시작

mm/dd/yyyy, --:-- --

종료

mm/dd/yyyy, --:-- --

시간	행위자	이벤트	대상	IP	상세
2026. 9. 11. 오후 9:30:52	admin	watchlist.view	watchlist - -	127.0.0.1	null
2026. 9. 11. 오후 9:30:52	admin	visitor.list	visitor - -	127.0.0.1	{"count":5}
2026. 9. 11. 오후 9:30:50	admin	kiosk.create	kiosk_device · 9b80435f-44e2-456b-815d-227e896500ce	127.0.0.1	{"name":"본관 로비 태블릿", "siteId":"00000000-0000-4000-8000-000000000001", "validDays":30}
2026. 9. 11. 오후 9:30:49	admin	roster.view	visitor_visit - -	127.0.0.1	{"count":1}
2026. 9. 11. 오후 9:30:46	admin	qr.verify	qr_token · 3af5469f-af93-4d25-9408-f2d4e10b25ad	127.0.0.1	{"result":"valid", "visitId":"59424e0d-3067-4612-9050-f8d1582fcd5b"}
2026. 9. 11. 오후 9:30:42	admin	visit.view	visit · 0b816f35-fc7d-4d6a-b4fa-b480fab218d	127.0.0.1	{"visitorCount":1}
2026. 9. 11. 오후 9:30:39	admin	frequent_visitor.list	frequent_visitor - -	127.0.0.1	{"count":0}
2026. 9. 11. 오후 9:30:38	admin	visit.view	visit · 0b816f35-fc7d-4d6a-b4fa-b480fab218d	127.0.0.1	{"visitorCount":1}
2026. 9. 11. 오후 9:30:34	admin	registration.invite	visitor_visit · 863738b5-c9ac-4fd1-a770-3450dae943b	127.0.0.1	{"expiresAt":"2026-09-14T21:30:34.594109826+09:00", "visitId":"2f2bb65c-ab4c-484a-a661-898e7d07cf2e"}
2026. 9. 11. 오후 9:30:34	admin	visit.view	visit · 2f2bb65c-ab4c-484a-a661-898e7d07cf2e	127.0.0.1	{"visitorCount":1}
		visitor_visit · bae75711-			{"lobbyId":"00000000-0000-4000-8000-0000

Audit Log — 이벤트 접두어·행위자·기간으로 거르고 CSV로 내려받는다

감사 로그는 이벤트 접두어·행위자·기간으로 필터링하고 더 보기 로 이어서 조회한다. 감사 로그, 방문 이력, 방문 통계는 각 화면의 CSV 버튼으로 내려받으며 화면에 적용한 필터가 그대로 적용된다. 파일은 UTF-8 BOM을 포함해 Excel에서 바로 열리고, 내보내기 자체도 감사 기록에 남는다. =, +, -, @ 로 시작하는 값은 앞에 작은따옴표를 붙여 Excel이 수식으로 실행하지 않게 한다. 감사 로그는 10,000행, 방문 이력은 50,000행이 한 번에 내려받는 상한이며, 상한에 걸려 잘린 파일은 마지막 행에 # 로 시작하는 안내가 붙는다. 그 줄이 보이면 기간이나 필터를 좁혀 나눠 내려받는다.

상태 점검 엔드포인트

메서드·경로	인증	용도
GET /healthz	없음	프로세스 생존. 컨테이너 헬스체크가 쓴다.
GET /readyz	없음	DB 연결, schemaVersion / expectedSchemaVersion , encryptionKey , 알림 대기열 적체(notificationBacklog , notificationOldestSeconds). 마이그레이션이 끝나지 않았으면 503 migration_pending . 롤링 배포의 준비 상태 점검에 그대로 쓴다.
GET /metrics	Authorization: Bearer <토큰>	Prometheus 지표. 토큰 미설정 시 404.
GET /api/v1/version	없음	버전·Commit·빌드 시각. 로그인 화면 하단과 같은 값.

로그

컨테이너 stdout에 JSON 한 줄씩(slog) 남는다. `docker compose logs -f visitflow` 로 본다. 모든 HTTP 요청은 `msg:"request"` 로 `method` , `path` , `status` , `duration_ms` , `request_id` 가 기록된다. 사용자 행위는 로그가 아니라 Audit Log 화면에 있다.

백업

PostgreSQL과 `ENCRYPTION_KEY` 를 같은 복구 시점으로 백업한다. 키는 Client Secret과 개인정보 복호화에 필요하므로 별도 보안 백업을 유지한다. 개인 API 키 원문은 서버에 없어 복구할 수 없으며 새 키로 회전해야 한다.

```
pg_dump "$POSTGRES_DSN" --format=custom --file=visitflow-$(date +%F).dump
# ENCRYPTION_KEY 는 비밀 저장소에 같은 날짜로 보관한다
```

복구는 새 데이터베이스에 `pg_restore` 한 뒤 같은 `ENCRYPTION_KEY` 로 컨테이너를 기동한다. 키가 다르면 `encryption key verification failed` 로 기동이 거부된다.

업그레이드와 되돌리기

```
# 1. 백업 (위)
# 2. 새 이미지 반입 — 아카이브의 visitflow:latest 별칭을 Compose가 바로 쓴다
docker load < visitflow-vX.Y.Z.tar.gz
docker compose up -d
# 3. 확인
curl -s http://127.0.0.1:8080/readyz # schemaVersion == expectedSchemaVersion, status ready
```

마이그레이션은 버전별 파일(`internal/database/migrations/NNNN*.sql`)로 관리하며 각 파일은 자신의 트랜잭션 안에서 한 번만 적용되고 `schema_migrations` 에 기록된다. 실패한 마이그레이션은 스키마와 버전 기록을 함께 되돌리므로 절반만 적용된 상태가 남지 않는다.

되돌리기: 스키마 마이그레이션은 앞으로만 간다. 이전 버전으로 돌아가려면 업그레이드 전 백업을 `pg_restore` 로 복구한 뒤 이전 이미지 태그(`docker tag visitflow:vX.Y.Z visitflow:latest`)로 `docker compose up -d` 한다. 업그레이드 뒤 만들어진 방문·감사 기록은 복구 시점 이후분이 사라지므로, 되돌릴지는 `readyz` 와 로그를 보고 빨리 정한다.

6. 장애 대응

증상	확인할 곳	조치
컨테이너가 바로 종료, 로그 configuration error ... missing required environment variables: ...	<code>docker compose logs visitflow</code>	네 환경 변수를 모두 넘겼는지, <code>BOOTSTRAP_ADMIN_PASSWORD</code> 가 12자 이상인지 확 인.
로그 database startup failed	PostgreSQL 접속 ·DSN· sslmode	기동 시 2분 동안 재시도한 뒤 포기한다. DB가 뜬 뒤 <code>docker compose restart visitflow</code> .
로그 encryption key verification failed	<code>ENCRYPTION_KEY</code>	그 데이터베이스와 함께 백업한 키를 넣는다. 새 키로 강행하는 옵션은 없다 — 데이터가 깨지는 것을 막기 위해서다.
로그 bootstrap administrator failed	DB 권한	<code>users</code> 테이블 쓰기 권한과 DSN 계정을 확인.
<code>/readyz</code> 가 503 <code>migration_pending</code> 또는 <code>schemaVersion < expectedSchemaVersion</code>	<code>/readyz</code> , 로그	마이그레이션 진행 중이거나 실패했다. 실패했으면 로 그의 SQL 오류를 고치고(주로 권한) 재시작하면 같은 파일부터 다시 적용된다.
<code>/readyz</code> 가 503 <code>database_unavailable</code>	PostgreSQL	DB 재기동 뒤 자동 복구된다.
방문자에게 문자가 안 감, 관리 Dashboard 알림 실패 증가	통계 · 알림 화면의 실패 사 유, 문자 API 테스트 발 송	Gateway 응답을 보고 API 설정을 고친 뒤 실패 일 괄 재시도 . 최대 5회, 5분 단위 Backoff로 자동 재 시도한다. 로그 <code>notification dispatch</code> ... 도 참 고.
<code>/readyz</code> 의 <code>notificationBacklog</code> 가 계속 증가	통계 · 알림, Gateway 상 태	API가 중지되었거나 응답이 없다. 중지된 API에 연결 된 대기 건은 취소되므로, 새 API를 등록하고 규칙을 다시 연결한다.
로그인이 429 , 화면 로그인 시도가 많아 N분 동안 잠겼습니다 가 전 직원에게	보안 · 키 → 신뢰할 Reverse Proxy	프록시 뒤인데 주소를 등록하지 않아 모든 요청이 프록 시 IP 하나로 집계됐다. 프록시 IP/CIDR(또는 <code>private</code>)을 등록한다. 특정 계정만이면 비밀번호 초기화 가 잠금을 푼다.
카메라 스캔이 안 됨, 화면 카메라는 HTTPS 또는 localhost에서만 동 작합니다	프록시 TLS, X- Forwarded-Proto	HTTPS로 종료하고 헤더를 전달한다. 그때까지는 USB 스캐너나 직접 입력.
MMS의 QR 이미지가 깨짐	일반 → 외부 기준 URL	Gateway가 접근 가능한 HTTPS 주소인지 확인. <code>{{qrcodeUrl}}</code> 은 이 값을 앞에 붙인다.

증상	확인할 곳	조치
아침에 방문자가 자동 퇴실됨	사업장 시간대, 방문 · QR 정책 → 자동 퇴실 시각	사업장 시간대가 실제와 다르다. IANA 이름(예 Asia/Seoul)으로 고친다.
통계 타일과 그래프 숫자가 다름	사업장 시간대	모든 집계는 사업장 현지 날짜 기준이다. 시간대를 바꾸면 그날부터 일치한다.
메일이 안 감	메일 (SMTP) → 테스트 메일 발송 , 로그 password reset mail failed	보안 방식·포트·인증 조합과 사설 인증서(TLS 인증서 검증 생략)를 확인.
MCP 클라이언트가 로그인 뒤에도 SSO 토큰이 이 서버를 위해 발급된 것이 아닙니다	로그 mcp oauth token refused 의 cause=	메시지의 azp 를 mcp.oauth.audience 에 적거나 Audience 매퍼에 리소스 식별자를 넣는다(4절 키 없이 SSO로 MCP 연결).
SSO 로그인 후 SSO 요청이 만료되었거나 유효하지 않습니다	Keycloak Redirect URI, 프록시 헤더	콜백 URL이 https://서비스주소/api/v1/auth/oidc/callback 과 정확히 같은지, X-Forwarded-Host / Proto 가 오는지 확인.
로그 panic	요청 ID로 앞뒤 로그	요청은 500으로 끝나고 프로세스는 계속 돈다. 재현 경로와 함께 이슈로 남긴다.

7. 보안

- **바꿔야 하는 기본값:** BOOTSTRAP_ADMIN_PASSWORD 는 첫 로그인 후 프로필에서 바꾼다. 로그인 실패 허용 횟수·잠금 시간, 세션 유효 시간, 개인정보 파기·감사 보존 기간, 동의 정책 버전은 회사 정책에 맞춘다. 동의 문구를 바꾸면 동의 정책 버전 을 올려 이후 동의와 구분한다.
- **외부에 열면 안 되는 것:** PostgreSQL 포트. 8080 은 리버스 프록시 뒤에만 두고 HTTPS로 종료한다. /metrics 는 토큰 없이는 404이지만 수집기 대역에서만 접근하게 한다.
- **리버스 프록시:** 보안 · 키 탭의 신뢰할 Reverse Proxy 에 프록시 주소를 IP 또는 CIDR로 등록한다(사내 대역 전체는 private). 등록된 주소에서 도착한 요청만 X-Forwarded-For 를 읽어 실제 접속 IP를 로그인 잠금, 공개 API 요청 한도, 동의 기록, 감사 로그에 사용하고, 나머지 요청은 헤더를 무시하고 TCP 접속 주소를 쓴다. 값을 비워 두면 어떤 요청에서도 헤더를 신뢰하지 않으므로 프록시 없이 노출된 설치에서 헤더를 위조해 잠금과 요청 한도를 우회할 수 없다.
- **접근 보호:** 로그인 실패는 요청 IP와 계정 각각 집계한다. 계정은 설정한 횟수, IP는 그 10배를 넘기면 잠금 시간 동안 429 와 Retry-After 를 반환하고 감사 로그에 auth.login_locked 를 남긴다. 잠금 정보는 데이터베이스에 있어 재시작·다중 노드에서도 유지된다. 모바일 방문증, MMS용 QR 이미지, 셀프 사전등록, 로그인 엔드포인트에는 IP 단위 분당 요청 한도를 적용해 토큰 열거를 차단한다.
- **QR과 개인정보:** QR에는 개인정보가 없고 랜덤 토큰 + HMAC 조회만 한다. 1회 사용과 Dynamic 주기는 방문 · QR 정책 탭에서 켜고, 재발급 시 이전 QR 폐기와 재사용(Replay) 감지는 항상 동작한다. 개인정보는 AES-256-GCM으로 필드 암호화되고 전화번호는 HMAC 색인으로만 검색된다. 목록은 마스킹되며 파기 기간이 지나면 자동 대체된다.

- **MCP SSO(OAuth):** 커먼 /mcp 는 개인 키 외에 Keycloak 액세스 토큰도 받는다. 토큰은 서명·발급자·만료·nbf·대상(aud / azp)을 검사하고 ID 토큰· cnf 토큰·HS256 서명을 거부하며, 등록된 활성 계정만 통과시키고 범위는 관리자 설정이 정한다. REST 경로에는 어디에도 토큰을 받지 않는다(4절).
- **인증 연동:** Keycloak OIDC(4절). 로컬 로그인을 끄면 로컬 로그인이 비활성화되어 있습니다 가 표시된다. 로컬 로그인을 끄기 전에 SSO로 super_admin 하나가 로그인되는지 반드시 확인한다.
- **세션·키 폐기:** 퇴직·유출 시 사용자·RBAC 표의 세션 종료 가 세션과 개인 API 키를 모두 폐기한다. 키오스크 기기 토큰은 방문 유형·키오스크에서 폐기한다.
- **방문 추적과 CSP:** 방문 추적 탭의 스니펫은 요청마다 nonce를 받아 실행되며 정책에 'unsafe-inline' 을 넣지 않는다(3절 방문 추적 스크립트). Momento는 같은 오리진 프록시를 기본으로 써서 외부 출처가 정책에 등장하지 않게 한다. 차단 신고 경로 /api/v1/tracking/csp-report 는 인증 없이 받지만 메모리의 출처 목록 100개 외에는 아무것도 저장하지 않는다.
- **감사:** 설정 변경(Before/After), 로그인 잠금, 내보내기, 승인·반려, 직접 체크인, 파기, 테스트 발송이 모두 Audit Log에 남는다. 보존 기간은 개인정보 탭에서 정한다.

부록. 기존 SMS Webhook 호환 계약

기존 알림 Adapter 탭의 Webhook은 아래 본문을 POST한다. 2xx를 성공으로 처리하며, 실패는 5분 단위 Backoff로 최대 5회 재시도하고 통계·알림 화면에 사유를 표시한다.

```
{
  "recipient": "01012345678",
  "message": "방문 안내 본문",
  "channel": "sms",
  "idempotencyKey": "notification-uuid"
}
```